安心办 BankPilot——带资金约束的银行事务智能体

安全自评报告

评估日期：2026年10月28日。评估方式：核心源码检查、已有验证记录对照与演示证据核对。评估范围：本地合成银行系统中的身份、权限、资金保护、执行一致性和恢复机制。本报告为团队自评，不是第三方审计、生产认证或赛事评委结论。

1. 评估对象、资产与信任边界

BankPilot允许用户用自然语言组织转账、账单、理财、卡片、订阅和生活目标。总控按需调度领域Agent并独立复核，API与Core执行身份、资金和授权规则。模型可以提出候选或说明问题，不能自行取得用户权限、修改余额或把一段“成功”文字当作交易回执。

当前业务数据、金融产品、账户、交易对手及提供方均为合成实现。API、PostgreSQL与Worker在本地真实运行，但没有真实银行、支付机构、卡组织或商户接入；因此本报告讨论沙箱控制，不据此推导真实资金或监管合规结论。

受保护对象	安全目标	主要信任边界
用户会话和资源	仅当前用户访问本人的账户、动作与业务记录	浏览器→认证API→Actor范围查询
付款对象、金额和版本	本人看到和授权的内容与最终动作一致	模型提案→确定性动作快照→授权证明
余额、占额和保护规则	不并发透支，不动用保护资金，不把未到账当现金	Core事务→账户记录、占额与规则版本
授权证明与Passkey	证明属于本人、当前动作和有效挑战，不可重放	认证器→服务端WebAuthn校验→一次性证明
付款和回执	同一命令不重复记账，超时后能查询原结果	Outbox/Worker→合成提供方独立事务→回执核验
业务历史与审计	可追踪谁在何时准备、授权、派发和核验动作	服务端写入→PostgreSQL持久化记录

前端展示、模型输出和用户提交的字段都需要服务端校验。提供方回执也必须与原请求及账本记录匹配。当前审计记录用于业务追踪，没有独立外部不可篡改存证；数据库管理员、主机失陷与真实机构安全属于尚未验证的部署边界。

核查入口：apps/api/src/app.ts、apps/api/src/webauthn.ts、packages/agents/src/index.ts、packages/core/src/index.ts及finance.ts、management.ts、investment.ts、goals.ts、worker.ts。本次未读取本地.env，未将运行密钥纳入材料。

2. 权限分级与逐动作授权

权限类别	代表操作	必需条件	不具备的权限
会话内普通只读	本人账户、账单、卡状态、合成持仓	已认证会话、Actor和资源归属校验	不因此获得付款、改卡或赎回许可
黄档查询授权	订阅明细查询	本人明确确认查询动作，服务端保存短时授权	查询授权不等于取消或拦截授权
黄档交易或管理	转账累计含本次≤1,000元；别名、订阅取消/银行拦截	当前动作哈希、本人确认、状态/版本/有效期及领域规则	不能代替红档强验证，也不能批量授权未展示动作
红档交易或管理	转账累计含本次>1,000元；卡片挂失/解挂；理财赎回	当前动作绑定的WebAuthn验证，服务端认可STRONG证明	注册Passkey或近期登录不能充当逐笔许可
目标计划	截止日、筹资依赖和后继付款	每个赎回/付款子动作按自身等级另行授权	建立目标不自动授权整条计划或到期扣款
模型与独立复核	理解、结构化提案、证据审查	只接收需要的上下文和输出契约	无资金授权、余额写入或提供方执行能力

转账累计口径。 源码tierFor以100000分为边界，按上海业务日统计成功与已授权在途金额，再加本次金额。恰好1,000元为黄档，超过为红档。准备候选不占额；授权在用户级锁中重算，因此两笔600元不能因并发或分属不同任务而都取得黄档权限。升档会更新版本与动作哈希，旧证明失效。

授权绑定。 转账摘要涵盖用户、动作ID与版本、账户、收款人、金额、币种、费用、备注、档位、有效期和固定策略版本。服务端核对当前哈希后，登记仅适用该动作的一次性证明。管理动作另外绑定操作目标及资源版本；订阅取消和拦截还受查询授权约束。

强验证。 SimpleWebAuthn在服务端核验签名、随机挑战、可信Origin、RP ID、用户验证标记及凭据归属。挑战存有用途、动作ID、动作哈希与有效期，消费后不能重复使用。凭据计数更新有数据库锁；验证失败或已使用挑战需要重新发起。

题面映射状态。 上述金额档位是已核对的源码实现策略。现有交付要求未附可逐条核验的正式题面金额阈值和完整判分矩阵，因此不能宣称已经满足题面阈值。账单“单笔≥1,000元”仅是大额支出提示；转账“日累计>1,000元”为红档，二者必须分别表达。

3. 资金、并发与执行安全控制

资金保护。 用整数分区分已确认余额B、有效在途占额R和保护资金P：当前可用A=B−R；P为最低生活保留加未来30天内到期及逾期未清义务；保护后可安排为max(0,A−P)。本次支出x必须满足A−x≥P，并通过金额、账户和余额检查。预演不占额，未来预计收入或赎回未到账资金不参与当前现金计算。

并发一致性。 授权、取消、规则更新等相关写入使用同一用户级事务锁；账户和动作读取结合数据库锁。授权时重算累计和资金，派发前再检查保护规则、当前证明与跨日风险。若派发前保护规则已变化，Core可阻止尚未发出的动作；已派发未知动作则不得作为普通取消释放。

状态与事务。 授权、占额、审计、证明和Outbox原子登记。Outbox向队列的投递与发送标记共享事务；Worker可能重投，因此提供方仍需固定请求身份和幂等检查。沙箱提供方采用独立事务，不能把本地Core与提供方当作一个跨系统原子提交。

情况	系统行为	保护的不变量
同命令同参数再次准备	返回原动作	重复点击不生成第二动作
同命令或提供方幂等键改参数	拒绝冲突	原身份不能用于另一金额或对象
普通确认用于红档	不授予红档执行权限	黄档确认不能升级为强证明
提交后超时	进入UNKNOWN并保留占额	未知结果不得当作失败释放资金
Worker再次处理已派发动作	以原请求查询	重投不造成第二次付款
查询暂未找到原记录	保持未知并继续查证	“查无”不冒充最终失败
查询得到原有效回执	核对请求、账户、收款人、金额、币种及回执内容后结算	只认原交易结果，不认模型或客户端成功声明
赎回受理但未到账	SETTLING并保留相关占仓	预计款项不得提前用于付款

最新V4受控演示中，第二笔600元设置为合成提供方“记账后超时”。本地保持结果待查与600元占额；用户在当前页面手动查原单后恢复成功。最终仍为两笔提供方付款、四条借贷分录、两份授权证明。这是本地合成场景中“不重复付款、不增加确认”的证据，不代表真实银行故障恢复。

AI侧风险主要通过“事实与生成分开”控制：原文槽位和实体需校验，账单统计与覆盖状态由程序保留，Reviewer不能覆盖资金否决。提示词是辅助约束，不是资金安全边界。

4. 验证证据及其限制

证据	已有结果	可支持的判断	不支持的推论
核心源码检查	会话Actor、动作哈希、版本、分级证明、资金保护、幂等与查单逻辑均有实现入口	存在明确服务端控制	不等于第三方审计或所有攻击路径安全
指定云模型已知回归	固定8例8/8；20次HTTP200、零重试和零结构修复	六领域代表请求及两项边界在该已知集通过	不等于盲测、未见质量、长期稳定性或完整云模型资金闭环
2026-10-28独立源码副本	135个测试文件、3,426项测试全部通过；类型检查、构建及隔离库清理通过，退出0	包含最新界面的588文件副本，以新依赖store完成检查	同一开发Mac验证；非接收方或Windows验收，未从最终ZIP解压后重跑
最新V4本地运行	新隔离账户；受控模型；真实本地API/PostgreSQL/Worker；300.25元付款与600元超时查原单	该素材采集中的本人确认、合成记账与原单恢复	不等于真实银行、云模型付款或连续录屏
历史受控资金验证	合成赎回到账后单独付款、刷新后恢复原单等结果有报告	对应版本和场景的本地资金链	不能把历史余额搬到V4，也不自动覆盖最新代码
历史虚拟WebAuthn	自动化浏览器曾验证协议与动作绑定	测试认证器环境中的签名校验	不等于实体Passkey、设备生物识别或银行认可交易签名

V4初始余额8,000元、保护5,000元。第一笔300.25元本人确认后余额7,699.75元；第二笔600元超时期间本地已确认余额仍为7,699.75元、占额600元，可用7,099.75元；查原单完成后余额7,099.75元、占额0。两笔累计900.25元，均属当前黄档，V4未使用Passkey，也没有刷新页面步骤。

V4采用实际页面状态截图，经过剪辑和相机运动呈现，不声称连续录屏。页面的“真实模型模式”是夹具配置标签，不能证明云模型调用。片中持续标注“本地合成银行·受控模型”。云模型已知回归与这些资金素材相互独立，不能拼接成云模型到资金执行的验收。

失败记录不回填：历史较早配置下的HTTP403没有可评业务输出，原因未在该报告确定；后续成功属于新的验证条件。历史资金验收首轮因工具错误读取不存在的物理列而在交易前失败，修正后才通过；原记录保留，正式正文不把修正后结果写成首次成功。

证据入口：docs/g9w-provider-revalidation.md、docs/evidence/2026-10-28-submission-source-verification.json、docs/g9v-submission-validation.md、docs/submission/video-evidence.md。

5. 已知风险、后续验证与自评结论

已知风险或缺口	当前影响	进入真实业务前需要的补充
正式题面风险矩阵未形成逐条映射	不能声明金额档位与赛事要求完全一致	取得题面原文，对金额边界、累计主体、读写分类和强验证定义逐项核对
合成提供方	无真实银行授权、清算最终性、退款争议或商户合同接口证据	在正式机构沙箱中验证权限、幂等、回执、最终拒绝及对账协议
模型样本小且已知	可能存在未覆盖语义、遗漏、拒答与服务不可用	冻结未见样本、输入与评分，单独验证质量、失败降级和长期表现
云模型资金全链未验收	云语义通过与确定性资金成功仍是两类证据	同版云模型生成候选，再完成本人授权、执行、账本及回执检查
实体Passkey未验收	设备体验、恢复和交易显示仍有未知	在目标设备验证实体或平台认证器；核对账户恢复及交易明细展示
生产数据与部署未评估	合成数据不能证明真实个人金融信息的隐私与运维安全	明确数据外发、保留删除、最小权限、TLS、密钥轮换、备份与恢复控制
日历和理财边界	DEMO_WEEKDAYS_V1只按合成周一至周五估算，无法反映法定节假日或真实产品净值	接入可验证交易日历与机构结算规则，保持预计与实际到账区分
审计和运维证据有限	本地数据库记录不等于不可篡改审计；无外部安全测试与生产容量结论	独立审计留存、告警、依赖漏洞管理、渗透及容量/容灾验证
最终归档仍有版本边界	10月28日独立副本3,426项测试通过，但未从最终ZIP解压后重跑	核对最终归档与已验副本文件及哈希；后续修改需按影响重新验证
接收方复现待记录	开发机独立目录成功不等于外部环境成功	接收方按README部署、测试并保留环境和结果

这些缺口不改变当前机制的可审查性，但限制结论的适用范围。作品可以展示：用户身份与动作绑定、权限分级、资金保护、逐动作授权、幂等记账，以及未知结果沿原请求查证。源码与已有测试提供机制证据，固定云模型回归提供有限语义证据，最新V4提供本地受控资金演示证据。

本团队自评结论为：当前适合在本地合成银行范围展示和复核银行事务控制方法，尚不具备据此宣称真实金融生产安全或完整云模型资金执行验收的依据。 正式题面符合性、真实机构接入、实体认证器、未见模型质量与生产运维必须独立验证，不由Agent数量、测试数量或一段演示视频替代。